

Проблема	Как нашли
Очередь запросов на сервере приёма платежей растёт быстрее, чем обрабатывается	По мониторингу: сравнить скорость поступления платежей и скорость обработки; посмотреть длину очереди во времени
Недостаточное количество потоков/воркеров обработки платежей	Метрики thread pool: все рабочие потоки постоянно заняты, запросы ожидают свободного обработчика
Медленные запросы к БД при обработке платежа	значительная часть времени запроса приходится на SQL; slow query log фиксирует долгие запросы
Исчерпан пул соединений с БД	Мониторинг connection pool показывает, что активные соединения достигают максимума, запросы ожидают соединение
Длительные транзакции блокируют обработку других платежей	По логам БД и мониторингу блокировок видны долгоживущие транзакции и lock wait
Синхронный вызов внешнего платёжного сервиса долго отвечает	Distributed tracing показывает большую длительность внешнего HTTP/RPC-вызова

Характеристика качества	Варианты решения
Производительность → пределы (capacity)	Горизонтально масштабировать обработчики платежей; добавить дополнительные экземпляры сервиса; настроить autoscaling
Производительность → ресурс	Увеличить размер пула потоков; разделить пулы для разных типов операций; подобрать размер пула нагрузочным тестированием
Производительность → время	необходимые индексы; устранить N+1; пересмотреть план выполнения запросов
Производительность → ресурс	Увеличить пул соединений в допустимых пределах; уменьшить время удержания соединения; оптимизировать работу с транзакциями
Производительность → время	Сократить транзакции; выполнять внешние вызовы вне транзакции; изменить порядок операций для уменьшения блокировок
Производительность → время	Асинхронная обработка; настроить timeout; использовать callback/webhook; выполнять независимые операции параллельно

Метрика
Длина очереди ≤ 100 запросов; отсутствие устойчивого роста очереди при штатной нагрузке
Загрузка пула $< 80\%$; время ожидания свободного потока p95 < 50 мс
Время SQL-запроса p95 < 100 мс
Ожидание соединения p95 < 20 мс; использование пула $< 80\%$
Время ожидания блокировки p95 < 50 мс; длительность транзакции p95 < 200 мс
Время внешнего вызова p95 < 500 мс; timeout rate $< 1\%$

Атрибут качества «Производительность»

Кейс: у пользователей **проблема:** слишком долгое время получения ответа в итоге платежи проходят. В чем причина, в каком модуле или элементе мы не знаем. Но видим, что у платежных машин вырастают очереди а функционирования продукта «Прием платежей» **можно домысливать** противоречие с условиями двух предыдущих слайдов. Логирование и

Источник стимула	Стимул	Окружение	Артефакт

Задача (все д.б. максимально реалистично и детально):**

- 1) локализовать проблему (найти проблемное место / **источник стимула** и кратко описать, с помощью чего его можно найти).
- 2) предположить, с чем в производительности (**подхарактеристики:** время, ресурс, пределы) связана проблема.
- 3) какая **реакция** системы ожидается.
- 4) предложить реалистичные способы (**тактики**) решения проблемы.
- 5) предложить, какой **мерой** оценивать результат воздействия на ситуацию.

ТЬ»

ответа о том, что платеж принят. Хотя в
енте инфраструктуры приема платежей
бонентов. Любые детали
самим, если домыслы не входят в
и мониторинг включены.

факт

Реакция

Мера реакции

↓

Результат: таблица Excel:

<проблема> - <как нашли> - <(под)>
характеристика качества> - <варианты
решения> - <метрика>

12+8
мин

nexign students

№	Подхарактеристика удобств	Особенности реализации
1	Целесообразность	Форма содержит только необходимое для операции поле лицевого счёта; понятное название и пример формата
2	Изучаемость	Контекстная инструкция доступна непосредственно из формы и объясняет проведение платежа
3	Безошибочность	После ввода счёта система автоматически показывает ФИО абонента и текущий баланс, позволяя проверить получателя до зачисления
4	Безошибочность	Перед необратимой операцией показывается отдельное подтверждение с получателем, счётом и суммой
5	Доступность	Управление с клавиатуры, логичный Tab-порядок, подписи для screen reader, достаточный контраст, ошибки обозначаются не только цветом
6	Эстетика	Итоговая сумма визуально выделена, но экран не перегружен; связанные данные сгруппированы
7	Управляемость	Основное и отменяющее действия визуально различаются; на основной кнопке указана сумма операции

Атрибут качества «Удобство использования»

Кейс: в продукт приема платежа входит **web-форма** для ввода платежа. Он
Нужно помнить, что удобства больше всего формальных подхарактеристи

Источник стимула **Стимул** **Окружение** **Артефакт** **Реакция**

Задача (** все д.б. максимально реалистично и детально):

Спроектировать самый удобный** с точки зрения характеристики качества "удобство использования" интерфейс внесения наличных (!) денег на счет абонента.

****Подхарактеристики удобства:** целесообразность, управляемость, изучаемость, безошибочность, доступность, эстетика.

Результаты:

1. Фото макета формы на ли элементов UI.
2. Таблица Excel:

<номер элемента> - <с какой связан> - <особенности реали подхарактеристики> - <метри неуспеха>



12+8 мин

Дмитрий Юшкевич

.+7

Например: +7 921 123-45-67

2. Абонент

Иван И.

Оператор: МТС

3. Внесено наличными: 500 руб

Вставьте купюры в купюроприёмник

Принимаются: 100, 200, 500, 1000

4. Комиссия:

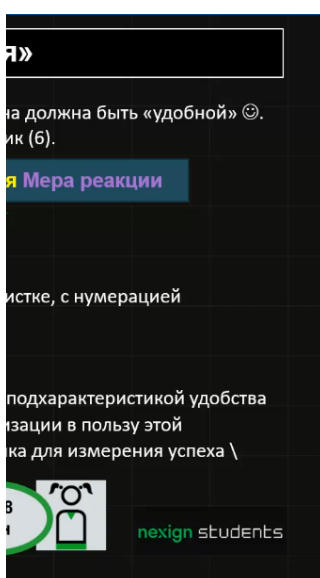
На счёт поступит

5. ☒ Получить электронный чек

Отмена

7. Нужна помощь?

Метрика
≥ 95% пользователей правильно понимают назначение поля без инструкции
≥ 90% новых пользователей самостоятельно проводят первый платёж без помощи другого сотрудника
Доля платежей, ошибочно зачисленных другому абоненту, < 0,1%
≥ 99,9% подтверждённых операций имеют правильного получателя и сумму
100% основных действий доступны с клавиатуры; соответствие WCAG 2.1 AA
≥ 90% пользователей за ≤ 2 с находят итоговую сумму в usability-тесте
≥ 95% пользователей с первой попытки выбирают требуемое действие



10
490

Пополнить

№	Нарушитель	Атакуемый модуль	Угроза
1	Внешний злоумышленник	Форма оплаты и канал передачи	Перехват платёжных данных при передаче
2	Фальшивомонетчик	Купюроприёмник	Фальшивое пополнение
3	Внешний злоумышленник	API / сервер приёма платежей	DDoS: массовая отправка запросов с целью исчерпания CPU, памяти, соединений или очереди
4	Внешний злоумышленник	БД платежей	изменение суммы/реквизитов транзакции через SQL-инъекцию
5	Сотрудник	БД платежей	Несанкционированное изменение транзакции напрямую в бд
6	Посторонний с чужой учётной записью	Вход в систему	Выдаёт себя за уполномоченного сотрудника и оформляет платежи.
7	Кассир, допустивший недосдачу	Сверка кассы и платежей	Не отражает приём наличных в системе либо оформляет сумму, отличную от полученной.
8	Вредоносное ПО	Очередь сообщений между модулями сервисов	Подмена сообщений о платежах внутри очередей

9	Внешний злоумышленник	Сайт приёма платежей	Создаёт похожий сайт, на котором кассир вводит учётные данные и данные операции.
---	--------------------------	-------------------------	---

Последствия

Утечка данных карты, мошеннические списания

Финансовый ущерб, Доля подозрительных/отклонённых купюр, сумма расхождений

Замедление/недоступность приёма платежей; RPS, CPU, длина очереди, доля ошибок, uptime

финансовые потери и число изменённых операций

Нарушение целостности финансовых данных. Все изменений данных должны иметь внутри бд отдельного автора и указанную причину

Операции от чужого имени; число входов и платежей с подозрительной учётной записи.

Расхождение учёта; сумма недостачи/излишка в Р за смену.

Другой сервис считает фиктивный платёж, совершит действия указанные в платеже и нарушит целостность данных

Компрометация доступа; число входов на поддельный адрес и инцидентов.

Тактика защиты	
Использовать TLS 1.2+; не передавать данные карты через открытые каналы	
Защита купюроприёмника, проверка подлинности, аудит операций	
Ограничение частоты запросов, защита от DDoS-атак с помощью межсетевого экрана веб-приложений, ограничение количества одновременных соединений и запросов от одного клиента.	
параметризованные запросы, контроль целостности, резервирование	
Запрет прямого изменения полей в продовой бд, разделение привилегий между ролями	
Личные учётные записи и второй фактор входа; запрет передачи пароля; блокировка сеанса при бездействии.	
Сверять в конце смены суммы чеков, записей платежей и наличных; фиксировать ответственного и время.	
Аутентификация между сервисами, подпись сообщений	

Атрибут качества

Кейс: клиент **максимальный** связанным с защищённостью

Источник стимула

Задача (все д.б. максимально детально):**

Обеспечить продукту «Приём» защиту. Для чего составить м... основываясь на известных и в... направлениях защищённости... защиты от декларируемых уг...

**** Модель угроз** - документ, опис... безопасности для продукта и мер... предотвращению.

****Подхарактеристики** защищённо... целостность, неподдельность, отс...

Открывать сервис через сохранённую корпоративную ссылку; проверять адрес; обучать сотрудников распознавать подмену.

а «Защищенность»

весовой коэффициент ставит характеристикам качества продукта, во всего процесса приема платежа. Таких подхарактеристик минимум 5.

на **Стимул** **Окружение** **Артефакт** **Реакция** **Мера реакции**

льно реалистично и

платежа» достойную
модель угроз** продукта,
вероятных (**стимулы**)
и продумать **тактику**
роз.

ывающий актуальные угрозы
ы по их минимизации и

ости: конфиденциальность,
леживаемость, подлинность.

Результаты: таблица Excel:

<нарушитель> - <атакуемый модуль \
элемент> - <угроза, способ ее
реализации, в т.ч. через что
воздействует> - <последствия, в т.ч. чем
измеряются> - <тактика \ мероприятия
защиты в ПО и не только>



12+8
мин



nexign students